

Well-Architected Review for a Secure Diversity Survey Platform

Document type	Security architecture review
Coverage	Cultural Infusion Atlas - synthetic research snapshot
Topics	AWS Well-Architected security reliability incident response survey platform
Source inspiration	https://atlas.culturalinfusion.com/secure-diversity-inclusion-survey-trust/

This document is a synthetic test artifact derived from themes and publicly visible metadata in the supplied Atlas article. It contains paraphrase, explanatory expansion and invented scenarios. It is not legal advice, a real client record, or a substitute for the original source and linked academic paper.

Review scope

This fictional review examines a multi-tenant diversity survey service from invitation through deletion. It includes the public survey application, identity separation, API, encrypted response store, reporting service, administrative portal, audit pipeline, backups, support access and third-party email delivery.

The review is inspired by the Atlas article's discussion of the AWS Well-Architected Framework. Findings and architecture names are invented. A completed review is a point-in-time assessment, not a certification or guarantee that every control operates continuously.

Security pillar

Strengths include centralised identity, least-privilege service roles, encryption, immutable administrative audit events, protected secrets and automated dependency scanning. High-risk findings include support engineers retaining broad production access, report exports lacking expiry, and insufficient monitoring of repeated small-cohort queries.

The remediation plan introduces just-in-time support access with approval, expiring signed export links, customer-controlled report permissions and alerts for disclosure-risk query patterns. Key use and export events are routed to a security monitoring account separated from the application environment.

Reliability pillar

Survey windows can coincide with organisation-wide campaigns, producing sharp invitation and submission peaks. The fictional architecture uses queue-based ingestion, idempotent writes, rate limits and multi-zone databases. Restore tests target a recovery point of fifteen minutes and recovery time of four hours for core response data.

Reliability must not weaken privacy. Failed submissions should not be copied into verbose logs, dead-letter queues should have the same access controls as the primary store, and support diagnostics should use synthetic records whenever possible.

Operational excellence

Runbooks cover survey launch, access provisioning, suspected disclosure, deletion request, key rotation, failed export and client offboarding. Changes to aggregation logic require code review, automated privacy regression tests and approval by both analytics and security owners.

Operational metrics include failed authentication, elevated access duration, export volume, deletion backlog, suppressed-query frequency, backup restore success and time to acknowledge security alerts. Raw survey answers are excluded from routine logs.

Performance and cost

Caching can improve dashboard response time but creates another location where sensitive aggregates may persist. Cache keys include tenant and permission context, entries expire quickly, and private responses are never shared across tenants. Performance tests include worst-case cross-tabs under disclosure controls.

Cost optimisation considers storage tiers and retention without keeping raw records merely because storage is cheap. Data lifecycle policies follow the approved purpose and retention schedule. Cost pressure is not accepted as a reason to reduce logging or recovery evidence.

Threat scenarios

Scenario One: a stolen administrator session attempts bulk export. Conditional access, short sessions, step-up authentication and anomaly detection limit the action. Scenario Two: an authorised analyst uses filters to isolate one employee. Query controls, minimum cohorts and audit review reduce inference. Scenario Three: a client requests restoration after deletion. Backup handling must honour documented deletion and retention commitments.

Scenario Four: a malicious survey prompt asks respondents to include names in free text. Template review, field warnings, moderation rules and client training reduce collection of unnecessary identifiers. Scenario Five: a vendor outage delays invitations but does not justify bypassing privacy controls.

Priority findings

Priority P1 is removal of standing support access within thirty days. P2 is deployment of query-pattern monitoring within sixty days. P3 is automated export expiry within forty-five days. P4 is quarterly restore and deletion verification. Dates and priorities are synthetic test facts intended to test exact retrieval.

Residual risk remains in contextual re-identification and client-side handling after a valid export. Contracts, product design, training and watermarking can reduce but not eliminate that risk. The platform should state the boundary clearly.